

Email encryption is encryption of email messages to protect the content from being read by entities other than the intended recipients. Email encryption may also include authentication. Email is prone to the disclosure of information. Although many emails are encrypted during transmission, they are frequently stored in plaintext, potentially exposing them to unauthorized access by third parties, including email service providers. By default, popular email services such as Gmail and Outlook do not enable end-to-end encryption. Utilizing certain available tools, unauthorized individuals may access and read the email content. Email encryption can rely on public-key cryptography, in which users can each publish a public key that others can use to encrypt messages to them, while keeping secret a private key they can use to decrypt such messages or to digitally encrypt and sign messages they send.

Encryption protocols

With the original design of email protocol, the communication between email servers was in plain text, which posed a huge security risk. Over the years, various mechanisms have been proposed to encrypt the communication between email servers. Encryption may occur at the transport level (aka "hop by hop") or end-to-end. Transport layer encryption is often easier to set up and use; end-to-end encryption provides stronger defenses, but can be more difficult to set up and use.

Transport-level encryption

One of the most commonly used email encryption extensions is STARTTLS. It is a TLS (SSL) layer over the plaintext communication, allowing email servers to upgrade their plaintext communication to encrypted communication. Assuming that the email servers on both the sender and the recipient side support encrypted communication, an eavesdropper monitoring the communication between mail servers cannot use packet sniffing tools to view the email contents. Similar STARTTLS extensions exist for the communication between an email client

and the email server (see IMAP4 and POP3, as stated by RFC 2595). STARTTLS may be used regardless of whether the email's contents are encrypted using another protocol.

The encrypted message is revealed, and can be altered by, intermediate email relays. In other words, the encryption takes place between individual SMTP relays, not between the sender and the recipient. This has both good and bad consequences. A key positive trait of transport layer encryption is that users do not need to do or change anything; the encryption automatically occurs when they send email. In addition, since receiving organizations can decrypt the email without cooperation of the end user, receiving organizations can run virus scanners and spam filters before delivering the email to the recipient. However, it also means that the receiving organization and anyone who breaks into that organization's email system (unless further steps are taken) can easily read or modify the email. If the receiving organization is considered a threat, then end-to-end encryption is necessary.

The Electronic Frontier Foundation encourages the use of STARTTLS, and has launched the 'STARTTLS Everywhere' initiative to "make it simple and easy for everyone to help ensure their communications (over email) aren't vulnerable to mass surveillance." Support for STARTTLS has become quite common; Google reports that on Gmail, 90% of incoming email and 90% of outgoing email was encrypted using STARTTLS by July 24, 2018.

Mandatory certificate verification is historically not viable for Internet mail delivery without additional information, because many certificates are not verifiable and few want email delivery to fail in that case. As a result, most email that is delivered over TLS uses only opportunistic encryption. DANE is a proposed standard that makes an incremental transition to verified encryption for Internet mail delivery possible. The STARTTLS Everywhere project uses an alternative approach: they support a "preload list" of email servers that have promised to support STARTTLS, which can help detect and prevent downgrade attacks.

End-to-end encryption

In end-to-end encryption, the data is encrypted and decrypted only at the end points. In other words, an email sent with end-to-end encryption would be encrypted at the source, unreadable to service providers like Gmail in transit, and then decrypted at its endpoint. Crucially, the email would only be decrypted for the end user on their computer and would remain in encrypted, unreadable form to an email service like Gmail, which wouldn't have the keys available to decrypt it. Some email services integrate end-to-end encryption automatically.

Notable protocols for end-to-end email encryption include:

Bitmessage

GNU Privacy Guard (GPG)

Pretty Good Privacy (PGP)

S/MIME

OpenPGP is a data encryption standard that allows end-users to encrypt the email contents. There are various software and email-client plugins that allow users to encrypt the message using the recipient's public key before sending it. At its core, OpenPGP uses a Public Key Cryptography scheme where each email address is associated with a public/private key pair. OpenPGP provides a way for the end users to encrypt the email without any support from the server and be sure that only the intended recipient can read it. However, there are usability issues with OpenPGP — it requires users to set up public/private key pairs and make the public keys available widely. Also, it protects only the content of the email, and not metadata — an untrusted party can still observe who sent an email to whom.

A general downside of end to end encryption schemes—where the server does not have decryption keys—is that it makes server side search almost impossible, thus impacting usability.

The content of an email can also be end-to-end encrypted by putting it in an encrypted file

(using any kind of file encryption tool) and sending that encrypted file as an email attachment.

Demonstrations

The Signed and Encrypted Email Over The Internet demonstration has shown that organizations can collaborate effectively using secure email. Previous barriers to adoption were overcome, including the use of a PKI bridge to provide a scalable public key infrastructure (PKI) and the use of network security guards checking encrypted content passing in and out of corporate network boundaries to avoid encryption being used to hide malware introduction and information leakage.

Setting up and using email encryption

Transport layer encryption using STARTTLS must be set up by the receiving organization. This is typically straightforward; a valid certificate must be obtained and STARTTLS must be enabled on the receiving organization's email server. To prevent downgrade attacks organizations can send their domain to the 'STARTTLS Policy List'

Most full-featured email clients provide native support for S/MIME secure email (digital signing and message encryption using certificates). Other encryption options include PGP and GNU Privacy Guard (GnuPG). Free and commercial software (desktop application, webmail and add-ons) are available as well.

While PGP can protect messages, it can also be hard to use in the correct way. Researchers at Carnegie Mellon University published a paper in 1999 showing that most people couldn't figure out how to sign and encrypt messages using the current version of PGP. Eight years later, another group of Carnegie Mellon researchers published a follow-up paper saying that, although a newer version of PGP made it easy to decrypt messages, most people still struggled with encrypting and signing messages, finding and verifying other people's public encryption keys, and sharing their own keys.

Because encryption can be difficult for users, security and compliance managers at companies and government agencies automate the process for employees and executives by using encryption appliances and services that automate encryption. Instead of relying on voluntary co-operation, automated encryption, based on defined policies, takes the decision and the process out of the users' hands. Emails are routed through a gateway appliance that has been configured to ensure compliance with regulatory and security policies. Emails that require it are automatically encrypted and sent.

If the recipient works at an organization that uses the same encryption gateway appliance, emails are automatically decrypted, making the process transparent to the user. Recipients who are not behind an encryption gateway then need to take an extra step, either procuring the public key, or logging into an online portal to retrieve the message.

Encrypted email providers

Since 2000, the number of available encrypted email providers has increased significantly.

See also

Email authentication – Techniques aimed at providing verifiable information about the origin of email messages

Email privacy – Overview regarding protection of personal privacy rights

End-to-end encryption – Secure communications method

HTTPS – HTTP extension supporting TLS encryption

Key (cryptography) – Used for encoding or decoding ciphertext

Mailbox provider – Provider of email hosting

Secure messaging – Method of exchanging information securely

== References ==